ONE-PAGE BRIEF

Post-quantum cryptography review: rabby @ 663c0e80e9f6

Client: Rabby Wallet (DeBank) — public repository (passive review) · Source: github.com/RabbyHub/Rabby, commit `663c0e80e9f6` · Reviewed: 2026-11-06 13:45 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
2 Critical **74** High **77** Medium
3 Low **3** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Critical QSI-2026-18467	**@openzeppelin/contracts 3.4.1-solc-0.7-2 is affected by GHSA-fg47-3c2x-m2wr (CVE-2021-39167)** What to do: Upgrade to a fixed version (3.4.2, 4.3.1).
Critical QSI-2026-18471	**@openzeppelin/contracts 3.4.2-solc-0.7 is affected by GHSA-fg47-3c2x-m2wr (CVE-2021-39167)** What to do: Upgrade to a fixed version (3.4.2, 4.3.1).
High QSI-2026-18454	**fflate 0.8.2 is affected by GHSA-px8p-9vwx-vf98 (CVE-2026-45820)** What to do: Upgrade to a fixed version (0.4.9, 0.5.4, 0.6.11, 0.7.5, 0.8.3).
High QSI-2026-18455	**lodash 4.17.21 is affected by GHSA-r5fr-rjxr-66jc (CVE-2026-4800)** What to do: Upgrade to a fixed version (4.18.0).

152 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium transaction and message signing	ECDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium role not determined	ECDSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 153; each needs checking against the code.

Static review of source code and manifests; files analysed: 1694. No requests were sent to the owner's systems.

Full report, content SHA-256: `737f869006f3ea348b2c1e6611f7869a5ab61eae8a6934d85e81cc96de6710f9`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.